

Rapport d'incident de sécurité

Compromission d'un poste de travail — Infostealer, proxy Man-in-the-Middle et exfiltration vers un serveur de commande & contrôle (C2)

Établissement	Établissement hôtelier indépendant (Paris) — anonymisé
Secteur	Hôtellerie
Auteur	Karim EL HAOURATI
Rôle	Réponse à incident (à titre individuel)
Période de l'incident	30 mars – 10 avril 2026
Classification	Confidentiel — version anonymisée
Version	1.0

Note d'anonymisation — Ce document est une version anonymisée destinée à un portfolio professionnel. Le nom de l'établissement et toute donnée à caractère personnel ont été retirés. Les indicateurs techniques (adresses IP, domaines, noms de fichiers) correspondent à l'infrastructure de l'attaquant.

1. Résumé exécutif

Entre le 30 mars et le 10 avril 2026, le poste de travail de la réception d'un établissement hôtelier parisien a été compromis par un logiciel malveillant de type *infostealer*. L'attaque combinait trois composants : un proxy Man-in-the-Middle local interceptant en clair l'intégralité du trafic du navigateur (dont l'accès à l'extranet de réservation Booking.com), un canal de commande et de contrôle (C2) exfiltrant les données vers un serveur situé en Europe de l'Est, et une campagne de phishing ciblé menée via WhatsApp contre les clients de l'établissement à partir de leurs véritables données de réservation.

Le signal initial n'a pas été émis par le système d'information mais par les clients eux-mêmes. L'investigation a permis d'identifier l'origine de la fuite, de neutraliser l'intégralité de la chaîne d'attaque, de reprendre la main sur les comptes critiques, puis de produire les livrables techniques et réglementaires (rapport, indicateurs de compromission, dossier de notification à la CNIL au titre de l'article 33 du RGPD).

2. Contexte et périmètre

- **Cible** : poste de travail de la réception (Windows), utilisé notamment pour l'extranet de réservation.
- **Rôle de l'auteur** : réponse à incident conduite à titre individuel, en parallèle d'un poste de réceptionniste.
- **Périmètre** : investigation du poste compromis, analyse de la chaîne d'attaque, confinement, remédiation et recommandations.
- **Nature de l'incident** : chaîne d'attaque complète — intrusion, interception, exfiltration puis exploitation frauduleuse.

3. Chronologie de l'incident

Date	Événement
30 mars 2026	Compromission initiale du poste (activation du compte local WsiAccount).
30 mars – 9 avril	Interception du trafic et exfiltration active des données (~10 jours).
8 avril 2026	Redémarrage inexpliqué du poste ; ralentissement du navigateur signalé par l'équipe.
9 avril 2026	Signalements clients de messages WhatsApp frauduleux — déclenchement de l'alerte.
9 – 10 avril 2026	Investigation, confinement et remédiation.
Avril 2026	Rédaction du rapport et préparation de la notification CNIL.

4. Détection — signal initial

Le signal initial n'est pas venu du système d'information mais des clients : plusieurs d'entre eux ont signalé des messages WhatsApp frauduleux contenant des informations de réservation exactes. C'est précisément cette exactitude (numéro de réservation, dates de séjour, prénom réel) qui a constitué l'alerte : un phishing générique ne dispose pas de ces éléments. J'en ai déduit que la fuite provenait nécessairement d'un accès direct au système de réservation de l'établissement, et non d'une fuite côté client.

Deux indices secondaires ont confirmé la piste : un redémarrage inexpliqué du poste de réception la veille, et un ralentissement du navigateur signalé par l'équipe.

5. Investigation technique

5.1 Processus et connexions réseau

- **python.exe** — proxy Man-in-the-Middle local en écoute sur 127.0.0.1:8080, 16 connexions établies.
- **AppLaunch.exe** — connexion C2 persistante vers 83.142.209.198:56001 (Europe de l'Est).

5.2 Détournement du trafic

L'analyse de la configuration proxy du navigateur et de WinHTTP a confirmé le détournement de l'ensemble du trafic vers 127.0.0.1:8080, permettant l'interception en clair — y compris l'accès à l'extranet Booking.com.

5.3 Mécanismes de persistance

Clés de démarrage automatique HKCU\...\Run, dont deux aux noms obfusqués en Unicode et un répertoire imitant un produit Adobe (masquerading).

5.4 Artefacts sur disque

- Python 3.12 installé hors droits administrateur, dans le profil utilisateur.
- Historique local VS Code contenant 10 versions itératives d'un script de scraping de l'extranet Booking.com — preuve que l'attaquant a développé son outil directement sur la machine.

5.5 Levée d'un faux positif

CardLock.exe (port 10086), d'abord suspecté d'être une porte dérobée, a été identifié comme un logiciel légitime de gestion des serrures (P701) simplement exposé sur un port non sécurisé.

5.6 Datation de la compromission

L'activation du compte local **WsiAccount** a permis de dater la compromission initiale au **30 mars 2026**.

6. Cartographie MITRE ATT&CK

Tactique	Technique	ID
Exécution	Command and Scripting Interpreter : Python	T1059.006
Persistance	Registry Run Keys / Startup Folder	T1547.001
Évasion défensive	Masquerading (imitation Adobe, noms obfusqués)	T1036
Accès identifiants	Adversary-in-the-Middle	T1557
Collecte	Browser Session Hijacking	T1185
Commande & contrôle	Application Layer Protocol (canal C2)	T1071
Exfiltration	Exfiltration Over C2 Channel	T1041

7. Indicateurs de compromission (IoC)

Type	Valeur	Description
IP C2	83.142.209.198:56001	Serveur de commande & contrôle (Europe de l'Est)

Type	Valeur	Description
Domaine	trustcontrol198-booking.info	Faux site Booking.com (collecte de coordonnées bancaires)
Binaire	AppLaunch.exe	Balise C2 persistante
Processus	python.exe : 127.0.0.1:8080	Proxy Man-in-the-Middle local
Persistance	HKCU\...\Run	Noms Unicode obfusqués + dossier imitant Adobe
Compte	WsiAccount	Compte local activé le 30/03/2026
Runtime	Python 3.12 (profil, hors admin)	Environnement d'exécution de l'outil
Artefact	Historique VS Code	10 versions d'un scraper Booking.com

8. Confinement et remédiation

- Arrêt du processus proxy et réinitialisation de la configuration proxy système et navigateur (WinHTTP + navigateur).
- Suppression des clés de persistance et des répertoires malveillants.
- Rotation complète des identifiants : extranet Booking.com (avec activation du 2FA), messagerie de l'établissement, compte Windows local, administration du routeur.
- Constitution du jeu d'IoC et rédaction d'un rapport technique complet.

9. Gestion de crise et conformité RGPD

- Alerte de la direction et sensibilisation de l'équipe de réception.
- Information des clients concernés de la fraude en cours, permettant d'éviter des paiements sur le faux site.
- Préparation de la notification à la CNIL au titre de la violation de données à caractère personnel (article 33 du RGPD).

10. Impact et résultats

- Chaîne d'attaque entièrement neutralisée : proxy arrêté, canal C2 coupé, persistance éliminée, poste assaini et connectivité rétablie.
- Fuite de données stoppée après une dizaine de jours d'exfiltration active ; interruption de la campagne de phishing faute de nouvelles données.
- Comptes critiques repris en main et renforcés (activation du 2FA sur l'extranet, absent auparavant).
- Production d'un rapport d'incident complet et d'un dossier de notification CNIL.

11. Recommandations de durcissement

- Déploiement d'une solution EDR sur les postes de réception.
- Blocage des installations logicielles hors droits administrateur (moindre privilège, AppLocker / WDAC).
- Segmentation du réseau back-office vis-à-vis des zones accessibles au public.
- Authentification multifacteur (2FA / MFA) sur l'ensemble des accès sensibles (extranet, messagerie).
- Filtrage des flux sortants (egress) vers des destinations connues et légitimes.

- Journalisation centralisée et supervision des postes critiques.
- Sensibilisation périodique du personnel à la sécurité et au phishing.

Document rédigé par Karim EL HAOURATI. Version anonymisée pour diffusion publique : nom de l'établissement et données à caractère personnel retirés.